

การป้องกันเว็บโดยใช้ไอพีเทเบิลส์

นาย นพสรณ์ เกษจันทร์	44015332
นาย สุภกร ชะอุ่มดี	44015350
อ. ธนา หงษ์สุวรรณ	อาจารย์ที่ปรึกษา
อ. อัครเดช วัชรระภูงษ์	อาจารย์ที่ปรึกษา
อ. ธนัญชัย ตรีภาค	อาจารย์ที่ปรึกษา
ปีการศึกษา 2546	

บทคัดย่อ

การรักษาความปลอดภัยในระบบเครือข่ายคอมพิวเตอร์ในปัจจุบันนั้น องค์กรทุกๆ องค์กรนั้นจะ
ใช้ตัวไฟร์วอลล์ในการรักษาความปลอดภัย ซึ่งเรียกได้ว่าระบบเครือข่ายนั้นจะขาดไฟร์วอลล์เสียไม่ได้

โดยปกติแล้วไฟร์วอลล์ที่เป็นแบบสเตทฟูลจะไม่สามารถที่จะป้องกันการโจมตีในระดับชั้น
แอปพลิเคชันได้ เช่น การโจมตีด้วยการส่งยูนิโค้ดเข้าไปยังตัว IIS เซิร์ฟเวอร์ และอื่นๆ ที่อยู่ในระดับชั้น
แอปพลิเคชันได้

ซึ่งกลุ่มผู้วิจัยเล็งเห็นว่ามีความจำเป็นที่จะต้องทำให้ตัวไฟร์วอลล์นั้นมีความสามารถที่จะป้องกัน
ในส่วนนี้ได้ จึงได้สนใจพัฒนาตัวไฟร์วอลล์ โดยเน้นไปที่ เน็ตฟิลเตอร์/ไอพีเทเบิล ซึ่งการพัฒนานี้เป็นการ
เพิ่มประสิทธิภาพให้กับตัวไอพีเทเบิลให้สามารถป้องกันการโจมตีในระดับชั้นแอปพลิเคชันโดยเอา
แนวคิดของการทำงานของ ระบบตรวจจับผู้บุกรุก (IDS) มาเป็นตัวช่วยตรวจสอบ ซึ่งจะเอากฎการ
ตรวจจับผู้บุกรุกมาเป็นกฎที่ใช้ในการตรวจสอบแพ็กเก็ตที่เข้าออกในระบบเครือข่าย

Web Prevention Using iptables

Mr. Noppasorn Kadchan

Mr. Supagorn Chaoumdee

Mr. Thana Hongsuwan Advisor

Mr. Akkradach Watcharapupong Advisor

Mr. Thanunchai Threepak Advisor

Academic Year 2003

ABSTRACT

Computer Network System, in the present. The organizations are used firewall that it can be protected network system. So maybe called the network system it without firewall

Normally, firewall was be stateful inspection that can't protected, attacking in application layer such as UNICODE attacking into IIS server and so on.

So that, my research team focus this inpoint improved firewall that proteced from them. Which we interested in netfilter/iptables so this devalopment was improved on iptables that can proteced from them in application layer. By used conceptual of Intrusion detection System (IDS) that its can improved. So the rules of instrusion detection can got from it that used in detected incoming and outgoing packet which it

กิตติกรรมประกาศ

ปริญญานิพนธ์ฉบับนี้สำเร็จลุล่วงได้ด้วยดี ก็เนื่องมาจากการให้โอกาส การดูแล ให้คำแนะนำ ต่างๆ การสนับสนุน การให้คำสั่งสอนและให้คำปรึกษาเป็นอย่างดีเสมอมาจาก จากอาจารย์ ธนา หงษ์สุวรรณ อาจารย์ อัครเดช วัชรภูพงษ์ และอาจารย์ ธนัญชัย ศรีภาค ซึ่งต้องขอขอบพระคุณอาจารย์ทั้ง 3 ท่านเป็นอย่างสูง

ขอขอบคุณภาควิชาวิศวกรรมคอมพิวเตอร์ และสถาบันเทคโนโลยีพระจอมเกล้าเจ้าคุณทหารลาดกระบังที่ได้จัดเตรียมสิ่งอำนวยความสะดวก เพื่อให้งานวิจัยดำเนินไปได้อย่างสะดวกและรวดเร็วไม่ว่าจะเป็นห้องวิจัยที่สะดวกสบาย อินเทอร์เน็ตความเร็วสูงสำหรับการค้นคว้าหาข้อมูลและการทดลองต่างๆเพื่อเป็นความรู้และประสบการณ์ที่ดี

ขอขอบคุณสมาชิกห้องวิจัยไอแซก (ISAG) ทุกคนไม่ว่าจะเป็นรุ่นพี่ รุ่นน้อง และเพื่อนๆร่วมห้องทุกคนที่คอยสร้างความสนุกสนานครั้นเคร่งช่วยสร้างบรรยากาศที่ดีและเป็นกันเองระหว่างรุ่นพี่ รุ่นน้องและเพื่อนๆ ช่วยคลายความเคร่งเครียดจากการเรียนและการทำวิจัย ทั้งยังคอยให้กำลังใจกันเสมอมา และต้องขอบคุณห้องวิจัยไอแซก (ISAG) ที่เป็นที่พักผ่อนในยามอ่อนล้า เพื่อให้มีแรงกายในการทำงานต่อไป

และท้ายที่สุดต้องขอขอบพระคุณบุคคลที่สำคัญที่สุดในชีวิตของข้าพเจ้าที่ทำให้ข้าพเจ้ามีทุกวันนี้ คือ บิดา มารดา และบุคคลทุกคนในครอบครัวของข้าพเจ้า อันเป็นที่เคารพรัก คอยอุ้มชูเลี้ยงดู อบรมสั่งสอนข้าพเจ้ามาเป็นอย่างดี ทั้งยังให้ความรักความห่วงใย และกำลังใจที่ดีเสมอมา ข้าพเจ้าต้องขอขอบพระคุณมา ณ ที่นี้ด้วย

นพสรณ์ เกษจันทร์

ศุภกร ชะอุ่มดี

สารบัญ

หน้าที่

บทคัดย่อภาษาไทย	I
บทคัดย่อภาษาอังกฤษ	II
กิตติกรรมประกาศ	III
สารบัญ	IV
สารบัญภาพประกอบ	VIII
สารบัญตาราง	IX
บทที่ 1 บทนำ	1
1.1 ความสำคัญและที่มา	1
1.2 วัตถุประสงค์ของโครงการ	1
1.3 ขอบเขตของโครงการ	2
1.4 ขั้นตอนการดำเนินงาน	2
บทที่ 2 โพรโทคอลทีซีพี/ไอพี	3
2.1 ความเป็นมาของโพรโทคอลทีซีพี/ไอพี	3
2.2 การเชื่อมต่อของโพรโทคอลทีซีพี/ไอพี (TCP/IP Linking)	3
2.3 โพรโทคอลทีซีพี (TCP: Transmission Control Protocol)	5
2.4 โพรโทคอลยูดีพี (UDP: User Datagram Protocol)	7
2.5 โพรโทคอลไอพี (IP: Internet Protocol)	8
บทที่ 3 ไฟร์วอลล์	12
3.1 คุณสมบัติทั่วไปของไฟร์วอลล์	12
3.2 ประเภทของไฟร์วอลล์	12
3.2.1 แพ็กเก็ตไฟเตอร์ไฟร์วอลล์ / สกรีนนิงเราเตอร์	12
3.2.1.1 ข้อมูลที่สำคัญของแพ็กเก็ต	13
3.2.1.2 ข้อดีของแพ็กเก็ตไฟเตอร์ริง	15
3.2.1.3 ข้อเสียของแพ็กเก็ตไฟเตอร์ริง	15
3.2.2 เซอร์กิตเลเวลไฟร์วอลล์ / สเตตฟูลอินสเปกชันไฟร์วอลล์	16
3.2.2.1 ความแตกต่างของการพิจารณาข้อมูลแบบแพ็กเก็ตไฟเตอร์ริงกับสเตตฟูล	16
3.2.2.2 ข้อดีของสเตตฟูลไฟร์วอลล์	17
3.2.2.3 ข้อเสียของสเตตฟูลไฟร์วอลล์	18
3.2.3 แอปพลิเคชันเลเวลไฟร์วอลล์ (พร็อกซี)	19
3.2.3.1 ลักษณะการทำงานของพร็อกซี	19
3.2.3.2 ขั้นตอนการนำพร็อกซีเข้ามาใช้งาน	19

สารบัญ (ต่อ)

	หน้าที่
3.2.3.3 ข้อดีของการใช้งานพรีอกรี	20
3.2.3.4 ข้อเสียของการใช้งานพรีอกรี	21
บทที่ 4 รูปแบบการโจมตี	23
4.1 การโจมตีเพื่อให้ปิดบริการ	23
4.1.1 ความหมายของการโจมตีเพื่อให้ปิดบริการ	23
4.1.2 ประเภทของการโจมตีเพื่อให้ปิดบริการ	23
4.1.2.1 การโจมตีประเภทอยู่ในชั้นทรานสปอร์ต หรือชั้นอินเทอร์เน็ต	23
4.1.2.1.1 การส่งแพ็กเก็ตจำนวนมาก	23
4.1.2.1.2 ความผิดปกติของแฟร็กเมนต์	26
4.1.2.3 การส่งแพ็กเก็ตแบบวนลูป	28
4.1.2.4 การโจมตีแบบผสม	28
4.2 การโจมตีเว็บแอปพลิเคชัน	29
4.2.1 ฮิดเด้นฟิลด์ (Hidden Field)	29
4.2.2 คุกกี้อายัด (Cookie Poisoning)	29
4.2.3 แบ็คดอร์และดีบั๊กออพชั่น (Backdoor & Debug Options)	30
4.2.4 แอปพลิเคชันบัฟเฟอร์โอเวอร์โฟลว์ (Application Buffer Overflow)	30
4.2.5 สเตลคอมมานด์ (Stealth Commanding)	30
4.2.6 เทคปาร์ตี้มีสคอนฟิกูเรชัน (3 rd Party Misconfiguration)	30
4.2.7 โนลเวอร์เนอริบิลิตี้ (Known Vulnerabilities)	30
4.2.8 พารามิเตอร์เทมเพอริง (Parameter Tempering)	31
4.2.9 ครอสไซต์สคริปต์ (Cross Site Script)	31
4.2.10 ฟอร์ซฟูลบราวซิง (Forceful Browsing)	31
4.2.11 ซอร์สโค้ดดิสคัลเชอร์ (Source Code Disclosures)	31
4.2.12 การโจมตีทางสถาปัตยกรรมของเว็บเซิร์ฟเวอร์ (Web Server Architecture Attack)	32
4.2.13 เอสคิวแอลพอยซันนิงแอนด์อินเจกชัน (SQL Poisoning & Injections)	33
4.2.14 ไมโครซอฟท์ไอไอเอสยูนิโค้ดบั๊ก (Microsoft IIS Unicode bug)	34
บทที่ 5 โครงสร้างและการทำงานของไอพีเทเบิล	35
5.1 รูปแบบการใช้งานไอพีเทเบิลเบื้องต้น	38
5.2 ฟังก์ชันแมทช์ (Match)	40
5.3 การระบุทาร์เก็ต (target)	48

สารบัญ (ต่อ)

	หน้าที่
5.4 การเดินทางของแพ็กเก็ตในระบบ	50
5.5 ฟิวเตอร์เทเบิลส์ (Filter Table)	53
บทที่ 6 เน็ตฟิวเตอร์	55
6.1 สถาปัตยกรรมของเน็ตฟิวเตอร์ (Netfilter Architecture)	55
6.2 พื้นฐานของเน็ตฟิวเตอร์ (Netfilter Base)	56
6.3 การพิจารณาแพ็กเก็ต (Packet Selection : IP Tables)	56
6.4 ส่วนขยายของไอพีเทเบิลส์ (Extending iptables)	56
6.4.1 ส่วนของเคอร์เนล (Kernel Space)	56
6.4.1.1 แมทช์ฟังก์ชัน (New Match Function)	57
6.4.1.2 ทาร์เก็ตฟังก์ชัน (New Target Function)	57
6.4.2 ส่วนของผู้ใช้ (Userspace Tool)	58
6.4.2.1 ส่วนของผู้ใช้ของแมทช์ฟังก์ชัน (Userspace Tool of New Match Function)	59
6.4.2.2 ส่วนของผู้ใช้ของทาร์เก็ตฟังก์ชัน (Userspace Tool of New Target Function)	60
บทที่ 7 หลักการออกแบบและการทำงาน	62
7.1 หลักการออกแบบ	62
7.1.1 แมทช์ฟังก์ชัน	62
7.1.2 ทาร์เก็ตฟังก์ชัน	62
7.2 การทำงานของโปรแกรม	63
7.2.1 คุณลักษณะของอินพุต (Input Specification)	63
7.2.1.1 คุณลักษณะของอินพุตจากการป้อนคำสั่ง (command)	63
7.2.1.2 คุณลักษณะของอินพุตจากแพ็กเก็ต	63
7.2.2 คุณลักษณะของเอาต์พุต (Output Specification)	63
7.2.2.1 คุณลักษณะของเอาต์พุตที่เกิดจากการกำจัดแพ็กเก็ต	63
7.2.2.2 คุณลักษณะของเอาต์พุตที่เกิดจากการแสดง และบันทึก (Logging) การโจมตี	64
บทที่ 8 การทดสอบการทำงาน	65
บทที่ 9 สรุปผลและวิจารณ์	72
9.1 ปัญหาและอุปสรรคในการพัฒนาโปรแกรม	72
9.2 แนวทางการพัฒนาต่อในอนาคต	72
บรรณานุกรม	74

สารบัญ (ต่อ)

ภาคผนวก ก. วิธีการติดตั้ง

ภาคผนวก ข. วิธีการใช้งาน

สารบัญภาพประกอบ

	หน้าที่
รูปที่ 2-1 แสดงการเปรียบเทียบเลเยอร์ของโอเอสไอกับเลเยอร์ของทีซีพี/ไอพี	3
รูปที่ 2-2 แสดงการข้อมูลที่ส่งผ่านใน โมเดลของทีซีพี/ไอพี	5
รูปที่ 2-3 แสดงการทำ 3-Way Handshake	5
รูปที่ 2-4 แสดงแพ็กเก็ตทีซีพี	7
รูปที่ 2-5 แสดงแพ็กเก็ตยูดีพี	8
รูปที่ 2-6 แสดงการทำแฟร์กเมนเทชัน	8
รูปที่ 2-7 แสดงการรีแอสเซมเบิล	9
รูปที่ 2-8 แสดงแพ็กเก็ตไอพี	11
รูปที่ 4-1 การ โจมตีด้วยฟLOODแอ็กแทค (Ping Flood Attack)	24
รูปที่ 4-2 รูปแบบแพ็กเก็ตที่เกิดขึ้นจากการ โจมตีจากฟLOODแอ็กแทค	24
รูปที่ 4-3 แสดงการส่งแพ็กเก็ตแบบซินฟLOOD (SYN Flood)	25
รูปที่ 4-4 แพ็กเก็ตที่เกิดขึ้นจากการ โจมตีแบบซินฟLOOD	26
รูปที่ 4-5 แสดงการรีแอสเซมบลีแบบปกติ	26
รูปที่ 4-6 แสดงการส่งเฉพาะแพ็กเก็ตสุดท้ายไปยังเป้าหมาย	27
รูปที่ 4-7 แสดงการรีแอสเซมบลีแบบแพ็กเก็ตมีขนาดเล็กลง	27
รูปที่ 4-9 แสดงการ โจมตีโดยส่งแพ็กเก็ตแบบวนลูป	28
รูปที่ 4-10 แสดงแผนภูมิแสดงประเภทของการ โจมตีเพื่อให้ปิดบริการ สำหรับสแต็กทีซีพี /ไอพี	28
รูปที่ 5-1 แสดงให้เห็นว่าแพ็กเก็ตมีเส้นทางการเดินทางอย่างไรเมื่อเข้ามา ในระบบตารางฟิลเตอร์ (filter table)	53
รูปที่ 6-1 แสดงการเดินทางของแพ็กเก็ตในเน็ตฟิลเตอร์	55
รูปที่ 8-1 แสดงภาพจำลองสภาพแวดล้อมของเครือข่าย	65
รูปที่ 8-2 แสดงการเปิดเว็บไซต์ตามปกติ	66
รูปที่ 8-3 แสดงการ โจมตีโดยใช้วิธีการไคเร็คทอรีทราเวอร์ซอล	67
รูปที่ 8-4 แสดงวิธีการ โจมตีเว็บเซิร์ฟเวอร์แบบเอ็กซ์พลอยต์ (exploit)	68
รูปที่ 8-5 แสดงผลจากการ โจมตีเว็บเซิร์ฟเวอร์แบบเอ็กซ์พลอยต์	68
รูปที่ 8-6 แสดงผลการ โจมตีด้วยวิธีการไคเร็คทอรีทราเวอร์ซอลหลังจากรันไฟร์วอลล์	69
รูปที่ 8-7 แสดงผลจากการ โจมตีแบบเอ็กซ์พลอยต์ หลังจากทำการรันไฟร์วอลล์	70
รูปที่ 8-8 แสดงรูปแบบการแจ้งเตือนผู้ดูแลระบบผ่านทางหน้าจอ	71

สารบัญตาราง

	หน้าที่
ตารางที่ 2-1 การทำงานของแต่ละระดับชั้นของทีซีพี/ไอพี	4
ตารางที่ 5-1 แสดงรายละเอียดของไอซีเอ็มพีแมสเซจ (ICMP message)	45
ตารางที่ 5-2 การเดินทางของฟอร์เวิร์ดแพ็กเก็ต (Forwarded packet)	51
ตารางที่ 5-3 การเดินทางของแพ็กเก็ตที่โฮสต์ปลายทาง (Destination localhost)	52
ตารางที่ 5-4 การเดินทางของแพ็กเก็ตที่โฮสต์ต้นทาง (Source localhost)	52